2026 SHENZHEN INTERNATIONAL FINTECH COMPETITION
International Track, Artificial Intelligence, Topic F: Agent Wallet

Tameng

a guarded AI wallet agent for cross-border remittances

SECURITY SELF-ASSESSMENT

Attribute	Assessment Specification
Target System	Tameng Autonomous Remittance Agent
Team Name	Larpathon
Audit Scope	provenance, detectInjection, lookalike, intentCheck, checkPolicy, store
Out of Scope	Base Sepolia consensus, third-party model provider
Lead Security Engineer	Habib Mukhlis Triatmojo (Policy Engine Lead)
Reviewing Officer	Muhammad Faris Revansyah (farisrevan13@gmail.com)
Track Weight	Topic F, Security and Compliance 30%
Build Status	120 automated checks passing; on-chain run complete
Date	20 October 2026

Submitted to: fintechathon@ican-x.com, WeBank Evaluation Panel, October 2026

Document Control and Audit Scope

Key	Value
Security Document Ref	TAMENG-SEC-AUDIT-2026-V1
Status	Final
Team Name	Larpathon
Target Network	Base Sepolia Testnet (Chain ID 84532)
Source Branch	main
Commit Reference	388b1067737f660c17eadb497dff21c396259cb1
Methodology	Static analysis, threat modeling, automated benchmark via POST /benchmark/run

1. Scope and Evaluation Methodology

This assessment covers the five security layers and the audit store. It reports what has actually been verified in the current branch and separates that from what still depends on a live on-chain wallet.

Table 1.1: Audit perimeter

In Scope	Out of Scope (External Dependencies)
provenance labeling and tool gating	Base Sepolia validator consensus
injection detection heuristics	Third-party language model provider
look-alike address detection	Physical theft of the owner's phone
calldata-to-intent matching	Base Sepolia public RPC availability
policy engine hard and soft rules	Domestic fiat off-ramp infrastructure

2. Permission Tiers and Enforcement

The owner may tighten limits but cannot raise them through chat or settings. Pause requires no PIN; resume requires a PIN. Five wrong PIN attempts lock transactions for 15 minutes. Every decision falls into one of three tiers.

Limits are bounded by compiled-in ceilings in policy/permissions.ts, independent of any chat message or settings call: a per-transfer limit of at most 500 USDC, a daily limit of at most 1000 USDC, a confirm threshold of at most 100 USDC, and a minimum buffer of 1 USDC so an auto-send can never be configured to empty the wallet.

Table 2.1: Permission tiers (allow / confirm / deny), confirm threshold 25 USDC

Intent Action	Tier	Condition	Owner Friction
Mandate run within limits	ALLOW	Active mandate, allowlisted, within caps	None

Intent Action	Tier	Condition	Owner Friction
Ad-hoc transfer below threshold	ALLOW	Allowlisted contact, under 25 USDC	None
Ad-hoc transfer above threshold	CONFIRM	Above 25 USDC confirm threshold	PIN or biometric
New mandate or contact change	CONFIRM	Structured settings flow	PIN or biometric
Recipient outside allowlist	DENY	Not a verified contact	None; reason shown
Look-alike address	DENY	Imitates a verified contact	None; warning shown
Instruction from EXTERNAL text	DENY	Provenance is EXTERNAL	None
Chain or action not allowed	DENY	Foreign chain or unsupported action	None
Any action while paused	DENY	Pause state active	None

3. Threat Model and Mitigating Controls

Each layer catches what the previous one may miss. The provenance layer labels every text as USER or EXTERNAL; a money order found in EXTERNAL text is never treated as the owner speaking. Mandate execution is a separate trusted source, not a third provenance label. The policy engine is the final authority, so a heuristic miss cannot move funds.

Table 3.1: Threats, controls, residual risk

Threat	Control Layer	Residual Risk
Instruction hidden in forwarded text	provenance.ts (EXTERNAL gating)	None for EXTERNAL text; it can inform but never transfer
Obfuscated injection (base64, Morse, zero-width, homoglyph)	detectInjection.ts	Heuristic; novel encodings may pass, but the policy engine still limits
Address poisoning imitation	lookalike.ts	Imitation caught; a wholly different address still requires confirmation
Calldata differs from confirmed card	intentCheck.ts + decodeTx.ts	Mismatch rejected
Limit bypass attempt	checkPolicy.ts	Hard rules enforced; owner can tighten but not loosen
Direct coercion by phone	Mandate floor + daily limit	Accepted human-layer risk, bounded by daily cap

4. Key and Secret Management

The testnet private key is stored in the .env file at the root of the repository within a single process; it never reaches the phone and is excluded from version control. On-

chain live execution is enabled only when TAMENG_LIVE=1 is explicitly set in the environment. A KMS, hardware enclave, and multisig are not part of this build and are future work.

Table 4.1: Secret inventory

Secret	Location	Access	Notes
Signer private key	.env (root)	Single Node process	Excluded from git; testnet only; live execution requires TAMENG_LIVE=1
Model API key	.env (root)	Agent module	Optional; an empty key falls back to the rule reader
Device token	env DEVICE_TOKEN	Server auth	Default demo-device; rotate before production
PIN	env APP_PIN_HASH	Server auth	Default demo PIN 123456; rotate before production
RPC endpoint	.env (root)	Server	https://sepolia.base.org

5. Audit Logging and Evidence

Every decision writes one append-only line to data/audit.log, including hash, amount, recipient, source, and a simulated flag. This log feeds the activity screen, the protection report, and the execution evidence file. Once transfers are non-simulated, the evidence is harvested from this log rather than recorded by hand.

6. Known Residual Risks

These risks are listed openly because a reviewer will notice them anyway:

Table 6.1: Known risks

Risk ID	Risk	Status / Treatment
R-01	Live on-chain transfers active via wallet key and RPC	Resolved
R-02	LLM reader is consulted only when the rules are unsure	Merged (TMG-1); every model output still passes the same policy engine
R-03	Injection detection is heuristic, not a guarantee	Policy engine stands behind it
R-04	Demo credentials (PIN 123456, device token demo-device)	Testnet only, no real funds at risk; kept as documented demo defaults for reviewer reproducibility on testnet, rotated before any production release
R-05	No live public server URL (LAN or tunnel only)	Accepted for this submission: demo shown via tunnel and video; every result is reproducible locally (npm test, POST /benchmark/run)

Risk ID	Risk	Status / Treatment
R-06	Off-chain policy enforcement	ERC-4337/7715 on-chain enforcement is future work
R-07	Testnet only, no custody guarantees	Stated in README and deck
R-08	Demo token uses Aave's Base Sepolia faucet USDC (0xba50Cd2A…4D5f), not Circle's official test USDC (0x036CbD…CF7e)	Circle faucet limits 20 USDC per address per 2 hours; 11 transfers recorded via Aave faucet USDC

7. Test Evidence

Automated checks: 120 passing via node:test (node --test), no external framework. Benchmark: 54 cases through the pipeline, 49 adversarial all blocked (49 deny decisions), 5 legitimate requests of which 2 executed and 1 clarified, and 0 unauthorized funds moved.

Table 7.1: Test evidence summary

Verification	Result
Automated checks (node --test)	120 passed, 0 failed
Total benchmark cases	54
Adversarial cases blocked (deny)	49
Legitimate requests (executed / clarified)	2 / 1
Unauthorized funds moved	0

8. Declaration

The on-chain run (TMG-12) has been completed, and benchmark numbers have been confirmed against the live wallet. The demo credentials listed in R-04 are kept on purpose so reviewers can reproduce the results on testnet, and no private key or other secret has ever been committed to the repository.

Signed on behalf of Team Larpathon:



Muhammad Faris Revansyah

Team Leader, Diponegoro University

20 October 2026